PRATICA FACOLTATIVA

Gestione di un'infezione WannaCry

Relazione personale – risposta a un incidente di sicurezza

Situazione e obiettivo

In questa pratica facoltativa ho considerato di lavorare come consulente di sicurezza per un'azienda che scopre di avere un computer Windows infettato dal ransomware WannaCry. Il mio obiettivo sarebbe prima di tutto limitare i danni ed evitare che l'infezione si diffonda agli altri computer della rete. Successivamente valuterei le possibili soluzioni per mettere nuovamente in sicurezza il sistema, considerando vantaggi e svantaggi di ogni scelta.

Cosa farei appena scoperta l'infezione

La prima cosa che farei sarebbe isolare il computer dalla rete. Scollegherei il cavo Ethernet e disattiverei il Wi-Fi, così da ridurre la possibilità che il malware raggiunga altri dispositivi o condivisioni aziendali. Non spegnerei o riavvierei il computer in modo automatico senza prima valutare la situazione con il responsabile IT, perché potrebbero essere necessarie attività di analisi e raccolta delle prove.

Avviserei subito il responsabile IT e il team che si occupa della sicurezza. Controllerei se ci sono altri computer che mostrano segnali simili e verificherei che i backup siano separati dalla rete compromessa. Annoterei l'orario in cui è stato rilevato l'incidente, i messaggi visualizzati e le attività già svolte. Eviterei di cancellare file o di provare strumenti casuali di rimozione prima di avere un quadro più chiaro.

Possibili soluzioni e valutazione

Isolare il computer

Il vantaggio principale è che si può contenere rapidamente il rischio di propagazione. È una misura immediata e relativamente semplice. Il limite è che il computer resta scollegato e quindi non può essere usato normalmente finché non è stato controllato.

Analizzare e rimuovere il malware
Userei strumenti di sicurezza affidabili, preferibilmente con il supporto del team IT o di specialisti di risposta agli incidenti. Questa attività può aiutare a individuare il malware e capire quali sistemi sono stati coinvolti. Tuttavia, rimuovere l'infezione non significa necessariamente recuperare i file che sono già stati cifrati.

Ripristinare i dati da un backup
Se l'azienda dispone di backup recenti e puliti, questa sarebbe una delle opzioni più utili per recuperare i dati. Prima di ripristinarli controllerei che i backup non siano stati raggiunti dall'infezione e che il sistema da recuperare sia stato messo in sicurezza. Il principale svantaggio è che i backup potrebbero essere incompleti o non abbastanza recenti.

Reinstallare Windows
Se non fosse possibile avere sufficiente fiducia nel sistema compromesso, valuterei una reinstallazione pulita di Windows e il successivo ripristino dei dati verificati. Questa soluzione permette di ripartire da una base più affidabile, ma richiede tempo e può comportare la perdita di dati che non sono presenti nei backup. Prima procederei, quando necessario, alla raccolta delle prove utili all'analisi.

Aggiornare e rafforzare la protezione
Prima di ricollegare il computer alla rete installerei gli aggiornamenti di sicurezza disponibili e verificherei la configurazione del sistema. WannaCry è noto per aver sfruttato una vulnerabilità di Windows legata a SMBv1; per questo controllerei che le patch siano presenti e che SMBv1 sia disabilitato se non è necessario per l'ambiente aziendale. Aggiornamenti e antivirus sono importanti, ma da soli non garantiscono il recupero dei file già cifrati.

Pagare il riscatto
Non considererei il pagamento del riscatto una soluzione affidabile. Non c'è garanzia che gli aggressori forniscano una chiave funzionante e il pagamento non assicura che il sistema torni sicuro. Prima di valutare qualunque decisione del genere, coinvolgerei la direzione, il team di sicurezza e i soggetti competenti.

Confronto sintetico

Opzione	Vantaggi	Svantaggi
Isolamento dalla rete	Contiene rapidamente la possibile diffusione.	Il computer non è disponibile per il normale lavoro.
Analisi e rimozione	Aiuta a individuare e rimuovere il malware.	Non garantisce il recupero dei file cifrati.
Ripristino da backup	Può recuperare dati e servizi.	Il backup potrebbe essere incompleto o compromesso.
Reinstallazione di Windows	Permette di ripartire da una base pulita.	Richiede tempo e può comportare perdita di dati.
Patch e rafforzamento	Riduce il rischio di una nuova infezione tramite vulnerabilità note.	Non risolve da solo i danni già causati.
Pagamento del riscatto	Non offre un vantaggio garantito.	Si può perdere denaro senza recuperare i dati.

Strategia che sceglierei

La soluzione che sceglierei non sarebbe una singola operazione, ma una sequenza di interventi. Per prima cosa isolerei il computer e avviserei il personale responsabile. Poi cercherei di capire quanto è estesa l'infezione, preservando le informazioni utili all'analisi. Dopo la verifica del sistema, valuterei se è possibile rimuovere il malware in sicurezza oppure se è preferibile reinstallare Windows. Ripristinerei soltanto dati provenienti da backup controllati, applicherei le patch e verificherei gli altri dispositivi prima di riportare il computer nella rete aziendale.

Infine, proporrei all'azienda di mantenere backup regolari e testati, aggiornare i sistemi, limitare i privilegi degli utenti, monitorare la rete e preparare una procedura da seguire in caso di incidente.

Conclusione personale

Da questa situazione emerge che la rapidità è importante, ma bisogna anche evitare interventi impulsivi. Isolare subito il computer può limitare i danni, mentre il recupero dei dati dipende dalla situazione e dalla disponibilità di backup affidabili. La prevenzione rimane fondamentale: sistemi aggiornati, backup verificati e una buona procedura di risposta possono ridurre l'impatto di un attacco come WannaCry.

Nota

Questa relazione descrive come affronterei lo scenario ipotetico proposto nella traccia. Non documenta un intervento realmente eseguito su un computer infetto.